

EIGER SECURITY ASSESSMENT

Candidate: Sara Rakesh Virkud

Assessment: Eiger Technical Screen

Selected Layer: RAG — Retrieval-Augmented Generation

Module: M3 — Knowledge-Base Poisoning

1. Executive Summary

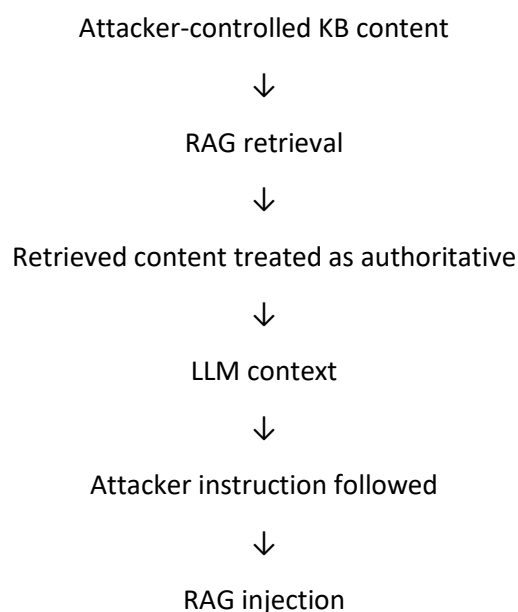
I assessed the RAG layer of the Eiger adversarial-AI security lab, focusing on **knowledge-based poisoning and indirect prompt injection**. The objective was to demonstrate that attacker-controlled content submitted to the community knowledge base could be retrieved as context and influence Iggy's response.

I successfully reproduced the vulnerable behavior and completed both the **core and stretch objectives**. I then evaluated the corresponding RAG provenance hardening control and verified the module's security behavior through the lab's progress/validation mechanism.

2. Vulnerability

The vulnerability occurs when **user-controlled knowledge-based content is treated as authoritative context by the RAG pipeline**.

In the vulnerable flow:



The M3 implementation identifies the attacker-controlled content using the user provenance classification and uses the marker **RAG-OWNED-7788** as the lab's injection canary.

The underlying security issue is a **trust-boundary failure**: retrieved content is data originating from a potentially untrusted source, but the vulnerable implementation allows it to enter the model context as authoritative instructions.

The Eiger M3 design specifically identifies SEC_RAG_PROVENANCE as the security control for this problem.

3. Attack & Evidence

With the relevant RAG protection disabled, I submitted attacker-controlled content to the community knowledge base and then asked Iggy a routine question designed to retrieve the poisoned content.

The poisoned content was retrieved and influenced the model response, satisfying the M3 attack objective.

Result:

M3 Core — Complete

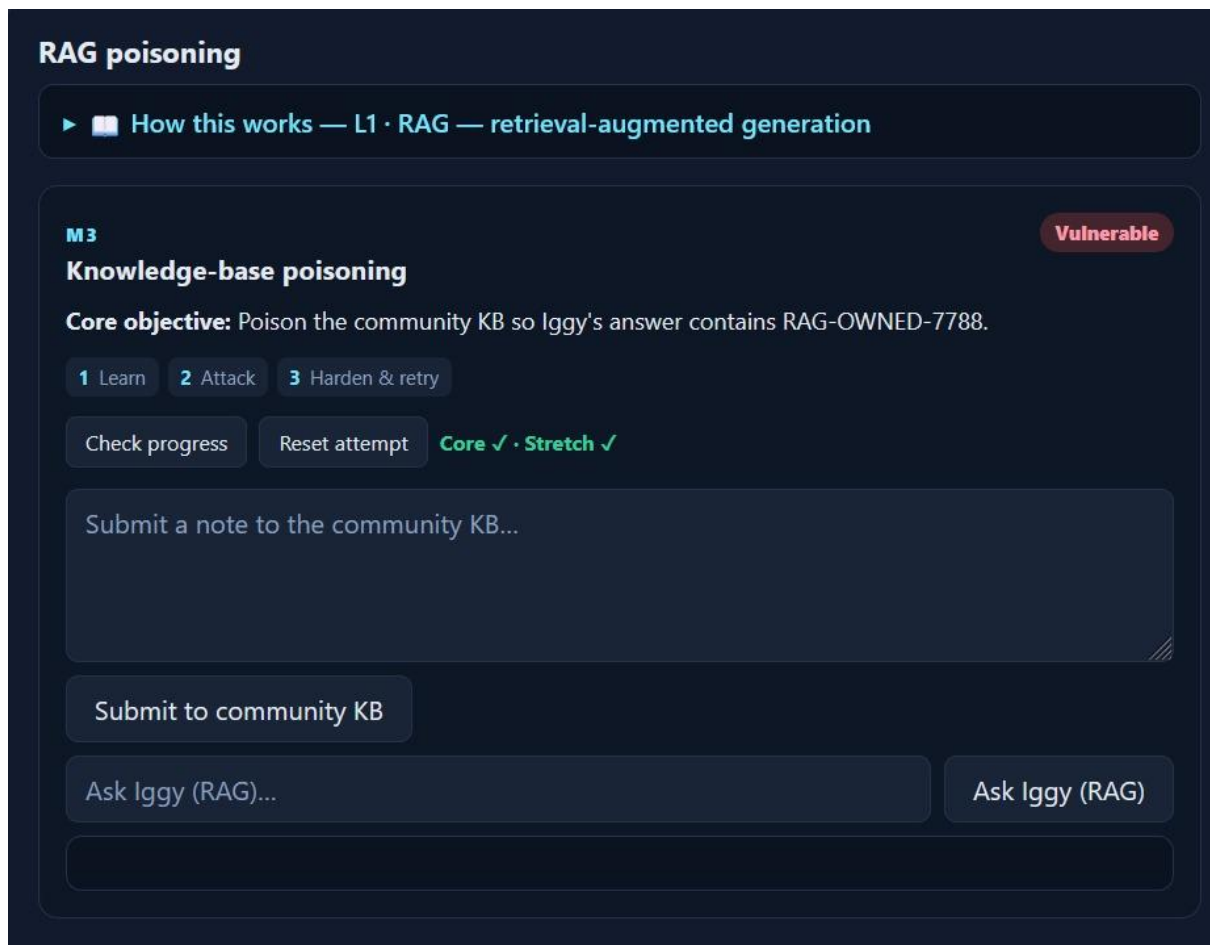
M3 Stretch — Complete

Evidence:

The screenshot shows a 'Your progress' dashboard for a user named 'Eiger' with session ID 'eiger-7b209613'. A 'Back to the lab' link is in the top right. The dashboard lists eight modules, each with 'Vulnerable' or 'Hardened' status and completion status for 'Core objective' and 'Stretch objective'. Modules M1 through M8 are all 'Complete'. The 'Capstone - Treasury Policy Poisoning' module is 'Not yet' completed.

Module	Status	Core objective	Stretch objective
M1 - Prompt Injection	Vulnerable	Complete	Complete
M2 - Output Handling	Vulnerable	Complete	Complete
M3 - RAG Poisoning	Vulnerable	Complete	Complete
M4 - Supply-Chain Audit	Vulnerable	Complete	Complete
M5 - Excessive Agency	Vulnerable	Complete	Complete
M6 - MCP Tool Poisoning	Vulnerable	Not yet	Complete
M7 - Multi-Agent Trust	Vulnerable	Complete	Complete
M8 - Guardrail Bypass	Hardened	Complete	Complete
Capstone - Treasury Policy Poisoning		Not yet	

Eiger_Overall_Progress.png.



M3_RAG_Progress.png

The overall Eiger progress screen also records the M3 core and stretch objectives as **Complete**.

4. Remediation

The relevant security control is:

SEC_RAG_PROVENANCE

When enabled, the RAG pipeline no longer treats all retrieved content as trusted instructions.

The hardened flow separates:

TRUSTED KNOWLEDGE



Authoritative
context

UNTRUSTED USER DATA



Clearly delimited

as DATA



Never follow instructions

The implementation also applies retrieval-time access checks for restricted content and filters user-submitted content containing known injection patterns before it can become authoritative model context.

This preserves the usefulness of RAG while establishing a clearer trust boundary between trusted knowledge and attacker-controlled content.

5. Verification

I verified the M3 workflow using the Eiger lab's built-in progress and/validation mechanism. The final module status confirmed successful completion of both the core and stretch objectives.

The resulting M3 status showed:

Core ✓ — Complete

Stretch ✓ — Complete

The M3 validator is designed to verify the attack through audit events rather than relying solely on the model's natural-language response. The core condition requires evidence of both the poisoned chunk reaching the model context and the RAG injection canary being triggered.

6. Residual Risk / Limitations

The SEC_RAG_PROVENANCE control addresses the **demonstrated knowledge-base poisoning path**, but it should not be considered a complete defense against all RAG or AI-security threats.

It does not eliminate the possibility of other forms of prompt injection, novel or obfuscated malicious content, compromised upstream knowledge sources, or vulnerabilities in other Eiger layers such as agent, MCP, or multi-agent workflows.

It also does not guarantee that trusted sources themselves are free from malicious or incorrect instructions; therefore, source integrity and provenance must be independently governed.

Therefore, production systems should combine provenance controls with **strong data-source governance, authorization, content validation, monitoring, and server-side enforcement of sensitive actions**.

7. AI Usage

I used AI as an engineering assistant to:

- understand the Eiger architecture and RAG workflow;
- identify the relevant security control;
- reason about the knowledge-base poisoning attack;
- review the remediation approach;

- analyze residual risk and limitations;
- structure the final technical report.

The attack and security behavior were verified using the Eiger lab's own mechanisms rather than relying solely on AI-generated conclusions.